

CAPÍTULO III

CONTROLES DE TI EN LAS PYMES

ASPECTOS NORMATIVOS Y TÉCNICOS A CONSIDERAR SOBRE EVALUACIÓN DE CONTROLES DE TI EN AUDITORÍA DE ESTADOS CONTABLES.

por: *Carlos Alberto Rumitti*

Resumen

En este capítulo trataremos la evaluación del control interno específicamente en lo referente al impacto de las Tecnologías de la Información, en adelante TI, en los procesos de generación de información y su incidencia en la valoración de riesgos de incorrecciones materiales por parte del auditor, a nivel estados contables, en adelante EECC y en las afirmaciones referentes a transacciones, saldos o información a revelar.



Nociones
del capítulo

Si bien la metodología de evaluación de controles y los procedimientos que describiremos son aplicables a otros encargos específicos de aseguramiento de TI, limitaremos el contenido solo a los relevantes para información financiera con impacto en los EECC.

Palabras clave

Controles de TI, aseguramiento de TI, riesgos de TI, integridad de datos.

1. Introducción

El enfoque de riesgos, si bien puede interpretarse como un concepto o una metodología a aplicar para un determinado fin, en auditoría se trata de un principio rector exigido por las normas vigentes tanto en el plano nacional como en el internacional.

En este marco, la Resolución Técnica N° 37 (RT 37) de la Federación Argentina de Consejos Profesionales de Ciencias Económicas (FACPCE), modificada por la RT 53 requiere en la sección III.A.i.3.5 "Obtener un conocimiento del control interno relevante para la auditoría..." refiriéndose específicamente a las TI con este requisito:

El conocimiento del control interno incluye el modo en que el ente ha respondido a los riesgos derivados de la tecnología de la información. Si el ente utilizase una *organización de servicios*, es necesario

considerar la obtención de un conocimiento del control interno en relación con dicha *organización de servicios* relevante para la auditoría.

Para finalizar el punto, define que el procedimiento implica "Relevar el control interno pertinente a su examen, incluyendo los aspectos relacionados con la tecnología de la información" y luego, evaluar su diseño e implementación.

En la sección III.A.i.3.8 la RT 37 enumera procedimientos a aplicar por parte del auditor, entre ellos, si decide confiar en determinados controles, probar su eficacia operativa¹ y con respecto a los procesos de generación de información (3.8.5) requiere la:

Constatación de los registros relevantes para la auditoría a través de la revisión de los procesamientos mediante los que la información se genera, utilizando técnicas analíticas, evaluando su integridad y seguridad.

Cumplir con lo dispuesto por la norma, implica que el auditor aplique procedimientos específicos sobre los controles de la entidad en su evaluación del entorno de TI, que en definitiva son los que garantizan la integridad y fiabilidad de la información.

En este marco, y por la especificidad requerida, actualmente la tendencia es que el auditor de EECC integre su equipo con expertos bajo los términos de la sección II.B.11 de la RT 37. Especialmente, entendemos que son aconsejables un experto en TI (evaluar si requiere experticia en seguridad de TI) y uno legal, especializado en derecho informático. El auditor evaluará en cada circunstancia

Cabe destacar que de acuerdo con la RT 37 un contador puede tener la necesidad de evaluar controles de TI si:

- Ejecuta un encargo de auditoría de EECC, en este caso, la tarea queda subsumida y es parte de la evaluación del control interno.
- Si el fin del encargo es evaluar objetivos de control específicos de TI, puede tratarse de:
 - Un encargo de aseguramiento a nivel general. RT 37: V.A.i.14.4.
 - Un informe sobre los controles de una organización de servicios. RT 37: V.A.i.14.5 y V.C.
- Si el fin del encargo es descriptivo/informativo, puede tratarse de procedimientos convenidos. Capítulo VII sección A de la RT 37.

Si bien los procedimientos a aplicar son comunes, nos abocaremos a algunos que consideramos relevantes cuando se trata de auditoría de estados financieros.

1 Completa de este modo la evaluación del control en sus tres etapas: diseño, implementación y eficacia operativa.

2. Control interno, incidencia de los controles de TI

Ya en el año 2000 las Directrices de Auditoría² (de sistemas de información) del Marco referencial COBIT emitidas por el IT Governance Institute, definían a la información y la tecnología que la soporta como el activo más importante de una entidad. Esto era así, dado la alta dependencia de las organizaciones a la información y la tecnología. Este concepto hoy está altamente potenciado y lleva a meditar si es posible concebir por separado un sistema de control interno y un sistema de control interno de TI, dado que prácticamente es imposible que un proceso se desarrolle en alguna de sus etapas o en su totalidad, sin un soporte de TI, ya sea tanto por los datos que genera como por el hecho que el comando operativo para su ejecución depende de ese soporte. Una parte cada vez más esencial de un sistema de control interno integrado, lo constituyen los controles de TI.

Desde el punto de vista que nos ocupa, los controles de TI y su impacto en el enfoque de riesgos de la auditoría de los estados contables, debemos considerar que, si bien se preparan de acuerdo con disposiciones legales y normativas emitidas por organismos de control o profesionales, son la "salida" de un proceso de generación de información que se nutre de lo que genéricamente llamaremos "procesos de negocios", que son los generadores de los datos. La correspondencia entre las "aplicaciones" del sistema de información que capturará y procesará esos datos y los procesos de negocios, operando en una plataforma de control de TI adecuada, constituyen un objetivo de control³ esencial a evaluar por el auditor.

Esto requiere por parte de la Dirección⁴ de las pymes una atención específica en el tono⁵ de sus políticas de control y en el auditor de estados contables, incluir como parte integrada a sus procedimientos de auditoría, los específicos derivados de su evaluación de riesgos de TI.

Con respecto a las pymes, es difícil generalizar conceptos dado que pueden diferir en tamaño y complejidad de procesos, sin que esto tenga necesariamente una interrelación directa, y con respecto a la Dirección, en términos generales puede suponerse que, en pequeñas dimensiones, la cercanía y participación de la Dirección (o dueños) en el ambiente y actividades de control es mayor. El auditor evaluará de acuerdo con su juicio profesional la valoración de riesgos realizada por la Dirección, y de acuerdo a su involucramiento y al tono de sus políticas con respecto a los controles de TI, como impacta en su auditoría.

2 Es usual y de uso difundido que se denomine "Auditoría de sistemas" a lo que en realidad son encargos de aseguramiento de TI, dado que la materia subyacente es distinta de información financiera histórica.

3 IT Governance Institute, (2000), Directrices de Auditoría del Marco referencial COBIT: Un Objetivo de Control en TI es una definición del resultado o propósito que se desea alcanzar implementando procedimientos de control específicos dentro de una actividad de TI.

4 Utilizaremos el término Dirección en forma genérica para representar a la máxima autoridad de la entidad, también podría tratarse de Gerencia, Consejo.

5 Orientación, energía, fuerza.

Analizaremos a continuación los controles específicos de TI a identificar por el auditor.

3. Controles de TI

Los controles de TI, como elementos integrantes de sistema de control interno, se ven influenciados en un primer nivel por las decisiones de la Dirección con respecto a la definición de políticas de control y la coherencia de la relación entre los recursos que asigne a TI y las necesidades de cada proceso de negocio. La Dirección definirá el marco general de control, el enfoque ético, los recursos, las comunicaciones y el monitoreo. En una entidad pequeña, es probable que este marco se encuentre despojado de formalismos, pero no libera al auditor de obtener los elementos de juicio necesarios para la definición de los procedimientos de auditoría posteriores.

Cabe aclarar que, ni el tamaño de la empresa ni el nivel de automatización de las aplicaciones de TI permiten presuponer la existencia de controles de TI adecuados, el escepticismo profesional solo debe satisfacerse con la obtención de elementos de juicio suficientes y adecuados.

Al respecto, dentro de los sesgos del auditor se destaca el de automatización, que consiste en dar mayor credibilidad a los controles automáticos, dado que operarán sin los condicionamientos de la voluntad o de la discrecionalidad. Sin embargo, si su definición es deficiente, funcionará despojado de condicionamientos, en forma automáticamente deficiente, cada vez que las casuísticas lo disparen.

A nivel procesos de negocios, como herramientas de TI, las aplicaciones de TI son programas o conjuntos de programas que se utilizan para el procesamiento de los datos generados por el proceso para facilitar su tratamiento, como podrían ser a modo de ejemplo los siguientes subsistemas:

- liquidación de haberes,
- proveedores,
- facturación y stock,
- administración de clientes,
- administración de rodados,
- costos y producción.

Estas aplicaciones (Gráfico 1) requieren controles específicos, denominados controles de aplicación, que se incluyen en los aplicativos de TI y tienen como objetivo otorgar una garantía razonable con respecto a la integridad, disponibilidad, confidencialidad y fiabilidad de los datos, desde que se generan hasta la salida de la información, ya sea en nuestro caso como información financiera, o cualquier otro tipo de salida con un fin específico, por ejemplo, un tablero de gestión, información de consumos, una liquidación de haberes, un informe de costos, entre otros.

Las aplicaciones de TI operan sobre una plataforma de servicios compartidos que se denomina infraestructura de TI que se integra por redes, sistemas operativos, bases de datos, comunicaciones, componentes de seguridad y ciberseguridad, hardware y su software relacionado.

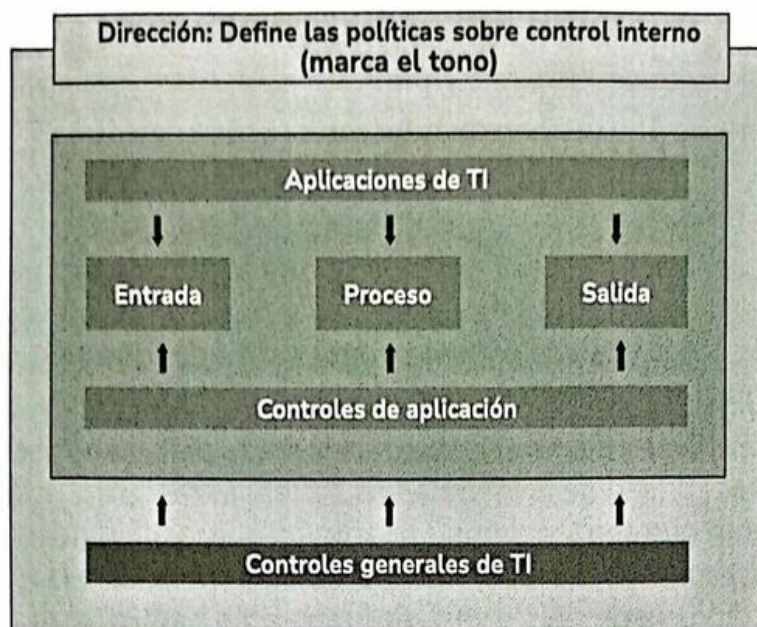


Gráfico 1. Estructura de control de TI

La infraestructura de TI también requiere de controles específicos. Sus objetivos son, además de la protección de la infraestructura y junto con otros controles generales de TI, brindar un marco de seguridad adecuado para el funcionamiento de las aplicaciones.

Desde la tarea del auditor de estados contables, reunir elementos de juicio sobre la confiabilidad de estos controles es esencial para sus propósitos. Desde luego, y a los efectos de la planificación de su auditoría, la evaluación de la materialidad de los controles estará en función a la materialidad de las afirmaciones sobre saldos, transacciones e información a relevar que surjan de los procesos de TI, es decir, el auditor deberá identificar los registros relevantes para la auditoría y en el marco de las TI, evaluar su integridad y fiabilidad.

Por último, un riesgo a destacar es que las aplicaciones pueden incluir almacenes de datos temporarios y procesos de compilación e incluso redacción de informes. Esto significa que, si el estado contable definitivo es la salida de un sistema con estas características, tiene la posibilidad de contener incorrecciones derivadas de riesgos de TI en la compilación, aun suponiendo que las afirmaciones ya auditadas estén libres de incorrecciones.

En los apartados 4 y 5 siguientes desarrollaremos controles generales y controles de aplicación específicos de TI.

4. Controles generales de TI

Como ya mencionamos, son controles que, a través de políticas, procedimientos y operaciones, tienen como objetivo brindar un entorno adecuado para el funcionamiento de las aplicaciones y la protección de la información, particularmente su integridad. Por sus objetivos, podemos calificarlos como críticos.

Sin pretender agotar el tema, dado que excede las posibilidades de este capítulo, describiremos algunos controles generales correspondientes a la infraestructura de TI y los que resguardan operaciones de TI.

4.1. Base de datos

Es una recopilación sistemática de datos que se almacenan⁶ en forma electrónica y en base a una estructura predefinida. Supone la definición previa de un modelo de datos y puede contener datos estructurados, textos, imágenes, videos, cualquier tipo de información.

Si bien todos los elementos de la infraestructura de TI son importantes a los efectos de la seguridad de la información, las bases resguardan el activo de TI más importante que son los datos. La razón es que, a diferencia de otros activos de TI, su pérdida es irreparable, y si se trata de un dato clasificado como crítico, su pérdida puede causar un daño irreparable o aún el cese de la entidad.

Es crucial la adecuada función del administrador de base de datos (DBA⁷ por sus siglas en inglés), que es un profesional encargado del mantenimiento, seguridad y funcionamiento de la base de datos. Algunas de sus funciones son controlar las copias de seguridad, monitorear la capacidad, la seguridad de acceso de usuarios, la estructura de datos. Ahora bien, la existencia del DBA implica la existencia de un área de TI, que puede no estar presente en las pymes, y esto puede ser más o menos crítico para el auditor de acuerdo con las circunstancias.

Si el auditado utiliza un software de tipo comercial⁸, generalmente contienen sus propias bases de datos, y en este caso:

- Si se trata de un sistema integrado, con interfaz directa entre las aplicaciones específicas (Ejemplo, stock, proveedores, sueldos) y la aplicación de contabilidad, contiene su propia base de datos y generalmente a ellos solo se puede acceder a través de las aplicaciones, ya sea para consulta o funciones de ABM⁹. En este caso, el auditor de EECC deberá verificar que esta condición de seguridad se cumpla y que la base de datos refleje adecuadamente el modelo de datos en función a sus objetivos, la información financiera.

6 Hemos utilizado una definición común ampliamente difundida de base de datos.

7 Database administrator.

8 Comunmente definido como enlatado.

9 Altas - Bajas - Modificaciones.

- Si se trata de aplicaciones no integradas, cada una de ellas almacenará sus datos, por lo tanto, para la elaboración de información se requerirá la ejecución de una transferencia de información entre ellas que puede ser definida en forma automática, o incluso puede ser una transferencia manual de archivos. Por ejemplo, las salidas del sistema de compras, que funciona independiente del de contabilidad consiste en información para realizar al asiento mensual de compras, los datos de detalle permanecen en la aplicación compras. ¿Qué sucede con proveedores? ¿Funciona con soporte en la aplicación compras? Si esto es así, el sistema no ofrece garantías de que alguna nota de crédito o débito o cualquier ajuste se registre directamente mediante la aplicación contable. Por otra parte, si Finanzas dispone de otra aplicación independiente que opera para programar sus pagos con Tesorería, tendrá el registro de proveedores en su propia base, y luego será transferido a la aplicación de contabilidad, en forma conjunta con los movimientos bancarios.
- Esta dispersión de información que podría ser más compleja que el ejemplo citado, existe en empresas con estructuras limitadas que han ido desarrollando el área de sistemas en la medida de sus posibilidades o sin la debida atención de la dirección, pero, deben presentar estados contables auditados. Esto implica un incremento en el riesgo de auditoría generado por el riesgo de incorrección material¹⁰ en la información derivada de esta estructura de TI. Para el auditor de EECC implica una mayor tarea y consiste como mínimo en:
 - Analizar los modelos de datos para entender la base de la estructura de la información que dispondrá, y su representación en las distintas bases para detectar la existencia de redundancias no deseadas o errores de diseño que puedan producir inconsistencias e incorrecciones. Si va a aplicar análisis de datos en sus procedimientos, esto es esencial.
 - Verificar que el acceso a las ABM de datos de las bases de las distintas aplicaciones solo sea a través de los usuarios autorizados por la aplicación, sin la existencia de usuarios privilegiados que puedan modificar datos sin autorización o sin la transacción de respaldo correspondiente. Esto incluye las tareas de mantenimiento de los programadores, cuando el usuario los contrata en forma particular, dado que conocen las llaves para el acceso a las bases y la circunstancia puede ser aprovechada para modificar información sin pistas de auditoría. Esto atenta directamente contra la integridad de la información y la fiabilidad de los datos por parte del auditor.
 - Verificar la integridad de la transferencia de las salidas de una aplicación en cuanto sea la entrada del siguiente proceso. En este caso, los procedimientos a aplicar consisten en la evaluación del diseño

10 En todos los casos que en este capítulo nos referimos a incorrección material puede ser producida por fraude o error.

del archivo de transferencia, sus controles de integridad con la información de origen, su implementación que puede resultar dificultosa por falta de documentación del proceso y siempre en estos casos, realizar prueba de cumplimiento de controles para verificar la integridad de las salidas de una aplicación y las entradas de la siguiente, en la cantidad en que el auditor de EECC lo considere de acuerdo a la definición de sus procedimientos posteriores.

- Verificar las actualizaciones de las aplicaciones para determinar en qué medida influyen en los procedimientos anteriores.
- Convivencia de aplicaciones integradas y no integradas. El auditor de EECC realizará los procedimientos descritos en los ítems anteriores según corresponda.

Las explicaciones que anteceden deben interpretarse exclusivamente con respecto a su impacto en las bases de datos. En el apartado 5 del presente capítulo nos referiremos a las cuestiones particulares de las aplicaciones.

Algunas aclaraciones requieren los motores de base de datos y los sistemas de gestión de base de datos (DBMS¹¹ por sus siglas en inglés). El motor de base de datos es un software que constituye el núcleo operativo que realiza las tareas técnicas y matemáticas de una base de datos, crear, leer, modificar y eliminar datos. En términos generales, se utiliza como sinónimo de DBMS, sin embargo, en un análisis más puntilloso podríamos decir que no lo es. Los DBMS incluyen, además del motor de base de datos para su operación, las herramientas de administración por ejemplo de consulta, clasificación y las interfaces para actuar con la base de datos.

Las bases de datos utilizadas en las pymes en su amplia mayoría son relacionales, es decir, su estructura es de filas y columnas vinculadas entre sí. La imagen de un Excel o un Acces las representa en forma adecuada. Difícilmente se encuentre una base jerárquica (viejos sistemas de pantalla verde, amarilla o blanca) pero los host con esta arquitectura siguen utilizándose en grandes organizaciones como por ejemplo bancos o sector público. El usuario ve las pantallas gráficas con las aplicaciones actuales, mientras que el sistema de base opera con pantallas monocromáticas o de texto (letras verdes, blancas o amarillas) y bases jerárquicas que tienen un grado de dificultad muchísimo mayor para elaborar informes y análisis de datos que las multirrelacionales. Sucede que entre el host y las aplicaciones de usuarios existe una arquitectura orientada a servicios (SOA¹² por sus siglas en inglés) que actúa como interfaz de usuario para facilitar la tarea.

No se espera encontrar bases jerárquicas en las pymes, pero si DBMS (sistema de gestión de base de datos) que actúan como interfaz de usuario

11 DBMS: Database management system

12 SOA: Service-oriented architecture.

capturando datos de distintas bases multirrelacionales o salidas de aplicaciones mediante su motor y luego elaborando con esos datos información financiera, que podría incluirse en los estados contables. Este es un caso por definición de riesgo para el auditor, dado que la transferencia de datos desde las bases origen hasta el informe final y los de procesos aplicados, son susceptibles de manipulaciones y por lo tanto contener incorrecciones materiales. Generalmente estos procesos de generación de informes no están auditados en las pymes. El auditor de EECC deberá controlar, además de los procesos, la integridad y fiabilidad de los datos y de las bases que los resguardan.

Por último, el auditor de EECC deberá evaluar su idoneidad para realizar controles de bases de datos, dado que, por el contenido altamente técnico de alguno de ellos, probablemente requiera la participación de un experto en TI, y de acuerdo a los datos que se trate, por ejemplo, en una institución de salud, la participación de un asesor legal con respecto al tratamiento de datos sensibles incluidos en las bases en función al objetivo de confidencialidad.

4.2. Sistema Operativo

Es un componente eminentemente técnico, por lo tanto, no nos extendemos en el desarrollo, dado que la evaluación de sus controles requerirá expertos en TI.

Se trata del principal sistema de una computadora. Consiste en un conjunto de programas que comandan y controlan los recursos de hardware y de software actuando como interfaz entre el usuario y el hardware. Como funciones tiene las gestiones de: memoria, procesos (multitasking), almacenamiento, dispositivos, usuarios, sistemas de entrada y salida, aplicaciones, control de accesos, seguridad.

Un hecho no deseado en el sistema operativo seguramente tendrá posibilidades de causar un efecto crítico en el sistema de información, por la pérdida o alteración de datos. Por ejemplo, una actualización puede tornar inoperable la versión de una aplicación con la consabida pérdida de la información, o puede requerir la adecuación de la base de datos, con el consiguiente riesgo de integridad.

Ejemplo de las causas que pueden producir estos hechos son:

- actualizaciones no autorizadas,
- accesos no autorizados,
- explotación de vulnerabilidades que posibilitan ataque, software malicioso o códigos maliciosos.

Un ejemplo con respecto al aprovechamiento de una vulnerabilidad podría ser la introducción de un Rootkit,¹³ una modificación del sistema operativo para permitir que un malware permanezca oculto, y luego actúe causando daños en los procesos o en los datos.

Las medidas de protección indican la actualización del sistema en forma adecuada, monitoreos, protección de accesos, prevención de ataques internos y de ciberseguridad y capacitación del personal.

Entendemos necesario que el auditor de EECC cuente con opinión de un experto con respecto al sistema operativo utilizado durante los procesos de información del período contable, y sus actualizaciones o cambios si los hubo y sus posibles efectos.

4.3 Controles de red.

Una red es un conjunto de hardware y software conectados entre sí, para enviar y recibir datos a través de impulsos electrónicos u ondas electromagnéticas, con la finalidad de compartir información, recursos y ofrecer servicios.

El auditor de EECC seguramente encontrará que la entidad utiliza algún tipo de red para sus operaciones, con la combinación de algunas de las siguientes características:¹⁴

- Con respecto a su alcance pueden ser de área personal (PAN)¹⁵, área local (LAN)¹⁶, área amplia (WAN)¹⁷, virtual de área local (VLAN)¹⁸. Por ejemplo, una empresa podría tener usuarios que se comunican con sus cercanos en forma limitada mediante dispositivos personales (PAN); en la oficina en general con una red virtual interna (VLAN); con sus sucursales de la ciudad a través de una red de área local (LAN) y con sus socios controlantes que se encuentran en el exterior, a través de una red de área amplia (WAN).
- Con respecto a su relación funcional: Cliente/Servidor, peer to peer.¹⁹

Como el sistema operativo, se trata de un componente de alto contenido técnico que requerirá la evaluación de un experto con respecto a la seguridad que brindan sus controles, dado que los riesgos son críticos, debido a que las vulnerabilidades propias o las amenazas a las que está expuesta la red, pueden afectar la integridad, disponibilidad y confidencialidad de los datos.

13 Tipo de software malicioso

14 Por razones de extensión no incluimos topología sobre la estructura de redes (Bus, estrella, anillo, malla, árbol, conexa, mixta).

15 Personal area network.

16 Local area network.

17 Wide area network.

18 Virtual local area network. Es una red lógica que se instala sobre una red local. Puede segmentarse en subredes cada una de ellas configurable en forma individual incrementando su rendimiento.

19 Peer to Peer - P2P – Traducción literal “de igual a igual”, conocida también como punto a punto.

Algunos ejemplos sobre vulnerabilidades serían debilidades en las configuraciones, falta de actualizaciones, falta de protección en la Wi-Fi²⁰ u otras de software y hardware. Ejemplos sobre ataques podrían ser malware, phishing²¹, DDoS²², intrusiones, robo de identidad, entre otros. Los dos objetivos esenciales de los ataques a nuestros fines son los datos (robo, alteración, destrucción) o producir la denegación de servicios.

En este marco, podríamos ejemplificar algunos efectos básicos a considerar por el auditor de EECC. Por ejemplo:

- Fuga o alteración de información afectando la integridad, confidencialidad y fiabilidad de los datos.
- Interrupción de servicio (DDoS u otros motivos). El hecho de interrumpirse temporalmente los servicios del sistema de información, no siempre es determinante para que las pymes puedan interrumpir sus operaciones, entonces los datos, que se generan independientemente que una aplicación los capture, se siguen generando y no es habitual que esté formalizado en un proceso de contingencia. La inserción posterior de esos datos al sistema es susceptible de incorrecciones o una oportunidad para hechos fraudulentos.
- Verificar si los procesamiento de información distribuidos se realizan utilizando las mismas versiones de software.
- Destrucción de información, afectando de este modo la fuente de las evidencias.
- Posibilidad de acceso a programas fuente y datos por by pass.

Existen soluciones de seguridad. Algunas de ellas son: instalación de firewalls, cifrado de datos, política de accesos, protocolos seguros, segmentaciones, entre otras. Las evaluaciones de los controles incluidos en estas soluciones y su efectividad requieren la intervención de un experto. La validación de controles de red es para el auditor de EECC, otro componente más del entorno de TI que aporta a la fiabilidad e integridad de los datos.

En otro orden, los avances tecnológicos permiten la utilización por parte de las entidades de algunos productos útiles, como por ejemplo el ACL, siglas en inglés del listado de control de acceso. Este mecanismo permite un control puntual sobre quién accede al sistema, desde que puerto (dirección IP) accede y que tiene permitido hacer (el usuario, la terminal o ambos). Es una herramienta que no solo ordena la operatoria, sino que brinda seguridad y detección.

Un caso de uso podría ser el siguiente: en pymes en que las áreas de administración y depósito están separadas, cuál sería el motivo del registro de un asiento contable desde el depósito a las 21 hrs. Por lo menos dispara

20 Wi-Fi: Wireless Fidelity – Fidelidad.

21 Phishing: Suplantación de identidad.

22 DDoS: Denegación de servicios distribuido.

la pregunta. Si la red está bien configurada esa operación no sería posible, y seguramente detectaría y registraría un intento.

Por último, las terminales de la red actualmente son inteligentes, es decir, capaces de operar por sí mismas²³. En estas estaciones de trabajo comúnmente denominado ambiente microinformático se baja información de las bases y se generan los informes, documentos de trabajo de asientos contables, preparación de estados financieros. La utilización de dispositivos personales es habitual en empresa pequeñas y no pequeñas. Desde el enfoque de auditoría de EECC esto implica a priori calificarlo como riesgo crítico, debido a la falta de medidas de seguridad característica de estos archivos y su alterabilidad o destrucción. El auditor evaluará cual es el procedimiento por aplicar para sustentar sus elementos de juicio, por ejemplo, copias impresas o digitales autenticadas, remisiones por correo y otro medio de comunicación, entre otras.

4.4. Resguardo de información

Comúnmente conocido como backup, consiste en una copia para resguardo y recupero de los datos, sistemas y bases de datos originales.

La experiencia nos indica que es un procedimiento crítico tanto por su ejecución como por su falta de ejecución en pymes, salvo las excepciones de rigor.

La política de resguardo es una decisión de la Dirección y un elemento clave del plan de continuidad de negocios. La pérdida de la información para la entidad podría significar la imposibilidad de continuar como empresa en funcionamiento, ante un hecho consumado, el auditor de EECC debe evaluar esta circunstancia.

La otra cuestión que debe ocupar al auditor con respecto a este punto es que cuando se retira de la empresa la fuente de sus elementos de juicio permanece a resguardo del auditado, es decir en un ambiente fuera de sus decisiones y en su documentación de auditoría. En síntesis, como ya hemos afirmado en otras oportunidades, llegada una situación de conflicto, los argumentos del auditor se respaldarán en la legitimidad y oponibilidad de su documentación de auditoría, y la capacidad que tenga esta para demostrar que la información utilizada era la obrante en las bases de datos del auditado al momento de realizar la tarea, cuestión que toma especial relevancia ante las evidencias digitales²⁴.

Hemos incluido en nuestra definición datos, sistemas y bases de datos, como concepto general. La Dirección no debe descuidar la plataforma de recupero. Por ejemplo, si solo resguarda datos y los sistemas son a medida o están parametrizados, tiene riesgo de no recuperarlos. Lo mismo sucede con las bases de datos y el sistema operativo. Ahora bien, si el daño fue

23 Salvo que estén expresamente configuradas para un fin, como por ejemplo una terminal de pagos, facturación, recepción o despacho. No son los ejemplos que nos ocupan

24 Remitimos al efecto al Capítulo 10 del Informe N° 25 emitido por FACPCE y a <https://www.youtube.com/watch?v=xX6klWu1wDA&t=1969s>

físico en el hardware, debe tener soporte donde realizar la recuperación y seguir operando.

Una precaución en particular debería tomar la Dirección respecto a los sistemas heredados.²⁵ Se trata de software o hardware de antigüedad, obsoleto, que ha caído en desuso en el mercado, no se actualiza, no se consigue y fue elaborado a medida sobre componentes que ya no se utilizan. Solo anticiparemos que un resguardo de datos sobre estas aplicaciones resultaría absolutamente inútil si no se contempla en forma completa el sistema y donde procesar el recupero. Nos referiremos a los riesgos para el auditor de EECC cuando tratemos los controles de aplicación.

Teniendo en cuenta los elementos a resguardar, hemos elaborado un cuadro comparativo Gráfico 2) que contiene las distintas modalidades en uso con sus ventajas y desventajas.

No hemos indicado la frecuencia, dado que eso estará definido por la política de seguridad de la entidad y si existiera, de una estimación de la cantidad de tiempo posible para recuperar una función empresarial (proceso de negocios) RTO²⁶ y de los datos que pueden perder RPO²⁷ y seguir funcionando.

Otro tema es donde alojar el backup, podría tratarse en un soporte físico en la entidad y/o fuera de ella, o en un soporte digital en la nube, que también estará en un soporte físico²⁸ pero en dependencias del prestador de servicios.

Tipo de respaldo	Archivos contenidos	Ventajas	Desventajas
Completa	Copia toda la información seleccionada.	La recuperación es mas sencilla y rápida.	Consume más tiempo realizarlo y ocupa más espacio. Tener en cuenta que en ningún caso es suficiente realizar solo una copia.
Incremental	Los que han cambiado desde la última copia completa o incremental según corresponda.	Consume menos tiempo y ocupa menos espacio.	La recuperación es más compleja y lenta. Requiere recuperar la primera completa y todas las incrementales posteriores.
Diferencial	Los que han cambiado desde la última copia completa.	Es más rápida que la completa y la recuperación es más sencilla y rápida que la incremental, dado que solo requiere disponer de la última completa y la última diferencial.	Depende la frecuencia con que se realice la copia de seguridad completa, las copia diferenciales crecerán en tamaño. Puede ocupar más espacio que el incremental.

Gráfico 2: Tipos de respaldo

25 Conocidos como legacy systems

26 RTO: Recovery Time Objective. Componente de los planes de continuidad de negocio.

27 RPO: Recovery Point Objective. Componente de los planes de continuidad de negocio.

28 Los datos si se trasladan a través de impulsos por ondas, solo en ese momento están en la nube. Siempre se almacenan en un soporte físico.

Las precauciones para tomar con el resguardo son esencialmente:

- Prever con que soporte recuperarlo.
- Esté protegido de daños físicos o lógicos, producidos por la obsolescencia, riesgos físicos del soporte o algún tipo de ataque.
- Tomar precauciones con respecto a Ramsonware²⁹, en la medida de lo posible.

Para un fin de utilización inmediata es posible y de hecho se utiliza tener la copia de resguardo en el propio servidor, sobre todo en empresas muy pequeñas. Si es para un fin inmediato y hay una copia resguardada fuera del equipo, no es aconsejable, pero tendría solución en caso de problemas. Nunca como única copia.

Lo ideal es más de una copia³⁰ y fuera del servidor e incluso de las instalaciones. Con respecto al uso actualmente generalizado de los servicios de nube, nos referiremos expresamente en el apartado 6 del presente.

Nos podemos dejar de destacar el punto más crítico de los sistemas de resguardo: Se acude a ellos solo en las contingencias, no como prueba rutinaria de recupero para verificar su funcionamiento, y esto no es solo patrimonio exclusivo de las pymes.

En base a las implicancias que puede tener para el auditor de EECC ya descritas, a continuación, agregamos el Gráfico 3, que contiene una guía para realizar un procedimiento indagatorio sobre los procesos de resguardo y recupero de información de la entidad.

Para su lectura, recomendamos tener en cuenta las siguientes aclaraciones y aprovechamos para resaltar que son aplicables al resto de las guías de este capítulo:

- En principio parece excesivo para las pymes, pero el auditor construirá su cuestionario pudiendo aplicar un criterio de adaptabilidad sobre los contenidos de esta guía, eliminando lo que considera que no aplica. También puede resultarle necesario ampliarla.
- El alcance de una indagación generalmente es informativo y no es suficiente para concluir sobre la confianza que puede inspirar el sistema de resguardo al auditor, salvo que la respuesta sea que no utiliza resguardos, entonces si es conclusiva.
- La columna (2), temas claves a considerar por el auditor, tiene un fin meramente informativo para poner en contexto algunas cuestiones.
- Los procedimientos indagatorios, preguntas de la columna 3, se complementan habitualmente con inspección, observación o procedimien-

29 Software malicioso que priva de la disponibilidad mediante el secuestro de datos, a cambio del pago de un rescate para su liberación.

30 Para ampliar recomendamos consultar a modo de ejemplo rotación cíclica, rotación padre-hijo, rotación abuelo-padre-hijo.

tos analíticos. Por ejemplo, si la respuesta a la pregunta ¿El responsable debe confeccionar una bitácora con instrucciones precisas de registro?, es afirmativa, se requiere solicitar la bitácora para tomar vista y también las instrucciones de registro para verificar que se hayan cumplido. Observación del registro e inspección del cumplimiento normativo. Este procedimiento es de aplicación para cada pregunta de la guía, debiendo el auditor definir para cada caso, cual es el procedimiento que aplicará ante cada respuesta.

- Las columnas (4) a (6) son de rigor.
- En la elaboración del documento de trabajo el auditor podrá agregar otras columnas, como por ejemplo comentarios, descripciones o indicadores si el auditado proporcionó documentación en la entrevista.
- El entrevistado será quién tiene la idoneidad para responder. Tratándose de pymes de estructura pequeña, probablemente participe el dueño con un operario o informático que se ocupe del tema. Otras pymes han definido áreas de cómputo o asesoramiento externo o han contratado servicios de nube.
- Si bien tiene un alto contenido de cuestiones de sistemas, todas aportan a la seguridad de los datos y su evaluación brinda una imagen del ambiente y las operaciones de control, útiles para la percepción de seguridad por parte del auditor. Como subproducto, algunas pueden agregar valor al informe sobre controles de la sección III.A.i.6 en el caso que se emita.
- Si el nivel de la pyme lo justifica, los objetivos de control de la guía pueden ser utilizados para elaborar una matriz de riesgo.

Gráfico 3

GUÍA PARA ELABORAR PROCEDIMIENTOS INDAGATORIOS SOBRE LOS PROCESOS DE RESGUARDO Y RECUPERO DE INFORMACIÓN DE LA ENTIDAD.					
Objetivos de control (1)	Temas claves a considerar por el auditor (2)	Preguntas sobre controles esperados. (3)	SI (4)	NO (5)	N/A (6)
Política de resguardo Participación de la Dirección.	La existencia de una política de seguridad marca el tono por parte de la Dirección y uno de los componentes de esa política son los resguardos. Como todo tema de control, su eficacia depende de la aplicación de arriba hacia abajo. Su involucramiento en los procesos de seguridad, marcan su interés, independientemente de su responsabilidad. Esto derrama en la organización.	¿Existe una política de resguardo, formal o informal? ¿Forma parte de una política integral de seguridad? ¿Cuál es nivel de involucramiento de la Dirección en la definición de actividades para la aplicación de la Política de resguardo? ¿La Dirección monitorea con cierta frecuencia la ejecución? ¿La dirección monitorea con cierta frecuencia las pruebas de recuperero?			
Información a respaldar	La Dirección define que resguardar, no el área de sistemas o en organizaciones más pequeñas el responsable técnico o un externo. La competencia de que respaldar es una decisión de la Dirección en todas las organizaciones, como hacerlo técnicamente es una propuesta del área de TI. La pregunta sobre el resguardo de los archivos de trabajo que resultan soporte de registros financieros es sumamente importante. Si no están incluidos en los elementos a resguardar, quedan fuera y ante un incidente en ese equipo, se perderá la información. Uno de los riesgos del ambiente microinformático.	¿Está definida que información se va a respaldar? ¿La definición incluye los siguientes elementos? - Archivos - Bases de datos - Aplicaciones - Sistema operativo - Otros (Detallar en comentarios) ¿Se resguardan los archivos de trabajo del ambiente microinformático?			
Tipos de respaldos	También se definirá de acuerdo a la mejor alternativa técnica, operativa, económica, evaluando los riesgos.	¿Está definido si se utilizarán alguna de las siguientes modalidades, además de la copia general? - Diferencial - Incremental			
Período entre respaldos	Este punto se define con los mismos criterios que el anterior. Podrían ejecutarse resguardos parciales al cierre de las operaciones diarias, o en organizaciones pequeñas, un resguardo completo durante la noche si no opera incluso todos los días. Si, es importante que la posibilidad de recuperero se extienda por un plazo prudente. Algunos malware se instalan en el sistema y se exteriorizan luego de incubar un tiempo. Esto es una cuestión eminentemente técnica de seguridad y deberá ser evaluada por personal idóneo.	¿Está definido cada cuanto tiempo debe realizarse un respaldo completo? Si se utilizan parciales ¿cada cuánto tiempo se realizarán? ¿Los tiempos prevén periodos razonablemente suficientes de recuperero ante la incubación de ciertos malware, por ejemplo: ramnsonware?			

continua

GUÍA PARA ELABORAR PROCEDIMIENTOS INDAGATORIOS SOBRE LOS PROCESOS DE RESGUARDO Y RECUPERO DE INFORMACIÓN DE LA ENTIDAD.					
Objetivos de control (1)	Temas claves a considerar por el auditor (2)	Preguntas sobre controles esperados. (3)	SI (4)	NO (5)	N/A (6)
Dispositivo a utilizar	Todos los dispositivos tienen riesgos y ventajas, tanto físicos como ambientales o de obsolescencia técnica. Un disco duro puede fallar en su mecanismo, rayarse y un disco sólido (SSD) luego de un número de ciclos de escritura/borrado, se agotan las celdas y no podrá leerse, y esto puede ser muy variable de acuerdo con el tipo de disco. Ambos son sensibles a cuestiones de tensión eléctrica. Sin embargo, son opciones válidas y las instrucciones del fabricante son útiles y necesarias al respecto. La nube tiene sus riesgos, que trataremos puntualmente.	¿El resguardo se realizará en uno o más de los siguientes dispositivos? - Disco duro en equipo complementario - Disco sólido externo. - Unidad de backup - En la nube - En otro soporte (describir en Comentarios)			
Sitios físicos de resguardo	Siempre es aconsejable por posibles siniestros guardar copias fuera de la entidad. El tema es que estén resguardadas y protegidas en función al riesgo de su contenido. También debe preverse al acceso cuando se requiera. Por ejemplo: si la copia está en la nube y por alguna cuestión no tiene acceso y el SLA no prevé una copia local, no podrá disponer del resguardo. Aún los lugares más seguros deben analizarse, la caja de un banco no permite su disponibilidad un domingo, y la empresa puede requerirlo.	Si no se utiliza nube ¿se resguarda en sitio externo una copia? Si utiliza nube ¿Tiene posibilidad de resguardar en sitio externo una copia como control complementario? ¿Tiene disponibilidad de acceso al sitio, aún en días feriados?			
Método de ejecución	En términos generales, la ejecución automática es más segura, siempre y cuando esté bien definida y se haya probado previamente y monitoree su funcionamiento adecuado.	¿La metodología adoptada es manual? ¿La metodología adoptada es automática? ¿La metodología adoptada es mixta?			
Personal adecuado para la ejecución	Si la ejecución es manual, el personal que lo realiza debe estar capacitado y definidos sus reemplazos con el mismo nivel de capacitación. También debe tener definidas claramente sus responsabilidades, de modo que su actuación no sea discrecional. Si el backup debe levantarse a las XX:XX has, es porque probablemente está definido un corte operativo y de actualización de archivo que torna óptimo ese horario. Si se ejecuta en XX + 1 hora, no es lo mismo y puede causar inconvenientes.	¿Se designó personal responsable para la ejecución de las opciones manuales? ¿Está capacitado? ¿Se designaron reemplazos ante contingencias? ¿Se designaron reemplazos por vacaciones? Luego de la ejecución - ¿Traslada en forma inmediata los soportes a su destino de reserva? - ¿Transmite el archivo a su destino en caso de que sea resguardo remoto o nube? - ¿Dispone de alguna normativa con instrucciones precisas que torne en no discrecional la tarea?			

continua

GUÍA PARA ELABORAR PROCEDIMIENTOS INDAGATORIOS SOBRE LOS PROCESOS DE RESGUARDO Y RECUPERO DE INFORMACIÓN DE LA ENTIDAD.					
Objetivos de control (1)	Temas claves a considerar por el auditor (2)	Preguntas sobre controles esperados. (3)	SI (4)	NO (5)	N/A (6)
Registros de actividad	La bitácora es esencial conjuntamente con la identificación de los soportes. Por un lado, para posibilitar el monitoreo y por otro por una cuestión operativa. Supongamos un método incremental con un resguardo completo los domingos y uno parcial por día. Si el sábado se produce un incidente y requiere recuperar información, deberá restaurarse el completo del domingo anterior más los cinco incrementales posteriores, pero en el orden cronológico en que fueron levantados. Procedimiento riesgoso, sin una identificación precisa de los soportes y una bitácora.	Si es manual ¿El responsable debe confeccionar una bitácora con instrucciones precisas de registro? Si es automático ¿El sistema registra en una bitácora las actividades?			
Monitoreo	Seguramente esta responsabilidad estará definida en la estructura de una empresa, pero en las pymes de tamaño pequeño, hay una alta probabilidad que recaiga operativamente sobre el dueño, si es que se involucra en este tema.	¿Está definido quién es el responsable del monitoreo? ¿Está definida la rutina de monitoreo? ¿Reporta a la Dirección?			
Recupero	Este es un proceso crítico. Mas allá del cuidado en su ejecución, requiere una constancia en el ejercicio del control que no se verifica con frecuencia en las pymes. Esta actividad forma parte de los planes de continuidad de la empresa y es esencial. Si se cumple todos requisitos descriptos anteriormente pero no se verifica que funcione... solo aporta incertidumbre y no seguridad.	¿Está definida una rutina de prueba de recupero (restore)? Si está definida: - ¿Contempla quién es el responsable de la ejecución de la prueba? - ¿Contempla las precauciones a tomar durante y después de la prueba? - ¿Se dispone de una bitácora para el registro de estas actividades?			
Tiempo de resguardo	Los tiempos de resguardo por cuestiones legales están definidos en las normativas y corresponde que los defina la dirección. La garantía debe ser la inalterabilidad de los registros por accesos no autorizados o por otros incidentes de seguridad y la posibilidad de recupero. Al respecto es necesaria la evaluación técnica por la posible obsolescencia técnica y económica. Este componente se potencia ante el avance en generación de transacciones que en todas sus etapas son digitales.	¿Está definido el tiempo de resguardo? (No podrá ser menor a las disposiciones legales como mínimo) ¿Existe un plan de resguardo que contemple la obsolescencia tecnológica y física? ¿Se designó un responsable operativo sobre este tema?			

4.5. Controles sobre adquisición, desarrollo y mantenimiento de sistemas

La accesibilidad a una amplia gama de productos y aplicaciones disponibles en el mercado, a un costo accesible o por lo menos inferior al de un área de desarrollo propio, más la oferta de las organizaciones de servicios a costos variables, marca una tendencia a la utilización de software comercial (SC) comúnmente denominados enlatados o a contratar servicios en la nube. Por lo tanto, el auditor de EECC puede encontrar los siguientes escenarios en el entorno de TI de la entidad:

- Utiliza exclusivamente SC para sus aplicaciones.
- Utiliza básicamente SC para sus aplicaciones, pero complementa con aplicaciones de desarrollo propio (puede ser tercerizado en desarrolladores independientes o área propia).
- Utiliza aplicaciones de desarrollo propio y complementa con SC.
- Utiliza servicios de nube en mayor o menor medida. Seguramente complementará con SC o desarrollo propio.

Es necesario que el auditor identifique que aplicaciones soportan los procesos de negocios y los contables, dado que los riesgos que implican son distintos de acuerdo al escenario en que se sitúen y por lo tanto la valoración de controles del auditor se verá influenciada.

El Gráfico 4 tiene como objetivo proporcionar una guía no taxativa sobre los temas claves a considerar por el auditor, los objetivos de control y las preguntas sobre controles esperados. Cabe aclarar que solo incluiremos controles generales y no funcionales de las aplicaciones que desarrollaremos en el apartado 5 de este capítulo y que se trata de una guía, de modo que el lector puede adaptarla modificándola, reduciéndola o incrementándola. Un tema en especial a tratar es el control de cambios.

Si bien el motivo del cambio en los sistemas se espera que sea legítimo y justificado, ya sea por la necesaria adecuación tecnológica, requerimiento de nuevos procesos de negocios o adaptación de los existentes, cambio de estructuras, entre otros, es un posible enemigo silencioso del control interno de TI si no está administrado, que además cobra mayor magnitud en estructuras débiles y su impacto directo es contra la integridad y disponibilidad de los datos o en las funcionalidades de las aplicaciones de negocios. Que se administren adecuadamente es de interés para el auditor de EECC, como todos los controles generales que directa o indirectamente tienen riesgo de impactar en los datos con efectos financieros.

Los objetivos de control a verificar se enfocan en que solo se realicen los cambios que hayan sido previamente probados en forma adecuada y se encuentren autorizados. Si se trata de desarrollos propios del auditado, el control de cambios debería formar parte de las metodologías de desarrollo, si se trata de SC, las nuevas versiones deberían ser evaluadas previamente a su instalación, por el posible efecto en los datos y como consecuencia, correcciones en los EECC.

En definitiva, los riesgos son el impacto de un cambio no autorizado, errores en los programas, alteraciones o pérdida de información, fraude.

Gráfico 4

GUÍA PARA ELABORAR PROCEDIMIENTOS INDAGATORIO SOBRE CONTROLES DE ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE SISTEMA						
Escenario (1)	Temas claves a considerar por el auditor (2)	Acuerdo de prestación de servicios (3)	Preguntas sobre controles esperados (4)	SI (5)	NO (6)	N/A (7)
Utiliza exclusivamente SC para sus aplicaciones	La seguridad sobre la integridad y disponibilidad de los datos depende de varias circunstancias. Por lo general permiten la parametrización, pero no el acceso a los programas fuentes o a las bases de datos. Si algunos permiten modificación de datos con alteración de la historia. Con respecto al acceso a los programas fuentes que podrían alterar funcionalidades con efecto en los datos o en las bases que permitirían actuar sobre los datos sin pistas, dependerá de la robustez de los bloques y criptografía del sistema y en gran medida de la confianza que puede depositar el auditor en el proveedor del software. Si el proveedor no transfirió los programas fuentes (de poca utilidad si la entidad no tiene un área de desarrollo y no dispone de la documentación del sistema) es esencial verificar la titularidad de la licencia de uso. De su vigencia depende el acceso a la aplicación y puede impedir la disponibilidad de los datos. Algunos desarrolladores resguardan su propiedad mediante la instalación de "bombas de tiempo" en el software que impide el acceso luego de determinado tiempo si no se actualiza la licencia. La garantía con respecto al soporte técnico y actualizaciones es otro tema para considerar. Otro riesgo vinculado al proveedor es su continuidad, el acceso a la aplicación tiene que estar vigente durante el período de resguardo obligatorio. En caso de siniestro que afecte la continuidad, posibilidad de reponer el mismo software para posibilitar la continuidad. Por último, control de versiones (Versionado). Permite al auditor verificar que una transacción se procesó con el mismo programa durante la vigencia de la versión.	Acuerdo de prestación de servicios. Uso legítimo. Vigencia de las licencias. Servicio técnico. Metodología de las actualizaciones. Disponibilidad definida de la aplicación Nivel de parametrización Controles de acceso Imposibilidad de acceso a programas fuentes o bases de datos por usuarios privilegiados Control de versiones	¿Existe un acuerdo de prestación de servicios? ¿Las licencias son legítimas? ¿Las licencias de uso están vigentes? ¿El período de vigencia de las licencias permite el resguardo de la información por el tiempo requerido? Si la respuesta anterior es no ¿Existen provisiones al respecto? ¿Las actualizaciones de software se realizan en la medida que se requieren? ¿Las actualizaciones de software están programadas, además de las requeridas? ¿El nivel de parametrización se adecúa a las necesidades del proceso de negocios que la aplicación soporta? ¿La aplicación tiene control de accesos mediante identificación de usuario y validación? ¿La aplicación prevé distintos roles de usuarios? ¿La aplicación prevé permisos de acuerdo con los roles de usuarios? ¿La aplicación prevé usuarios especiales con acceso a bases de datos? ¿La aplicación prevé usuarios especiales con acceso a los programas fuentes? ¿La aplicación cuenta con control de versiones? ¿La aplicación cuenta con registros de log?			

continua

GUÍA PARA ELABORAR PROCEDIMIENTOS INDAGATORIO SOBRE CONTROLES DE ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE SISTEMA						
Escenario (1)	Temas claves a considerar por el auditor (2)	Acuerdo de prestación de servicios (3)	Preguntas sobre controles esperados (4)	SI (5)	NO (6)	N/A (7)
Utiliza básicamente SC para sus aplicaciones, pero complementa con aplicaciones de desarrollo propio (puede ser tercerizado en desarrolladores independientes o área propia). Utiliza aplicaciones de desarrollo propio y complementa con SC	Con respecto a las SC corresponden las apreciaciones sobre SC. Si se trata de desarrollos propios puede ser interno con personal propio o tercerizado en software a medida. En este último caso se aplica SC. Desarrollo propio implica una estructura de desarrollo, que generalmente es menos que proporcional a las necesidades, y esto implica riesgos por saturación de estructura. Si es desarrollo propio requiere una metodología de desarrollo. Actualmente se utilizan metodologías ágiles, que prácticamente han desplazado los métodos tradicionales en cascada (ciclo de vida CDV). Para cualquiera de las metodologías que utilice la entidad, la etapa de desarrollo es esencial porque en ella se diseña la aplicación y se definen tanto las funcionalidades como los controles. Con respecto a estos últimos, es la oportunidad de prevenir controles que funcionarán como detectores de acciones no autorizadas. También en esta etapa se realizan las pruebas pre-implentación de la aplicación. Particularmente, el método ágil implica la entrega de sucesivas aplicaciones incrementales hasta la entrega final. Esto puede generar algún efecto en los datos dado que la aplicación comienza a operar por etapas y requiere un grado de sincronización con el proceso de negocio.	Solo para desarrollos propios: Metodología de desarrollo adoptada Planificación del área Documentación (importante para la evaluación del diseño) Utilización de productos estándares de desarrollo (licenciados) o software libre. Participación del usuario Autorización pre-implentación Control de versiones Cumplimiento de normas.	¿Existe una planificación adecuada de tareas? ¿Existe una metodología de desarrollo adoptada, por ejemplo: CDV o Ágil? ¿Se documentan los desarrollos en forma adecuada? ¿Si la metodología es Ágil, existe documentación al menos esencial de las iteraciones? ¿Existen licencias por lo productos de desarrollo? ¿Utilizan software libre? ¿El usuario participa en las etapas del desarrollo y prueba de la aplicación? Si la metodología es Ágil ¿se verifica una participación intensa del usuario? ¿Está definido quién es el que autoriza la puesta en producción de la aplicación? (Puede ser más de uno, porque generalmente son transversales) ¿Se contemplan las normas legales que pueden tener incidencia en el proceso? ¿Se contemplan los requisitos legales con respecto a datos personales? ¿Se lleva una bitácora con control de versiones?			
Utiliza servicios de nube en mayor o menor medida. Seguramente complementará con SC o desarrollo propio.	Ya nos referimos a SC y desarrollo propio. Con respecto a la contratación de servicios de nube (cloud computing), dependerá de la modalidad de contratación si se trata de una nube de terceros. En forma sintética diferenciaremos dos tipos de contratación: IaaS por sus siglas en inglés que significa infraestructura como servicio y SaaS también por sus siglas en inglés, que significa software como servicios. Si la modalidad es IaaS, se contrata la infraestructura (servidor, SO, almacenamiento, red...) y el usuario instala sobre ella sus aplicaciones que podrán ser desarrollos propios o no. Si la modalidad de contratación es SaaS, directamente se contratan las aplicaciones que proporciona la organización de servicios. Debido a las posibles implicancias técnicas, el auditor evaluará la utilización de un experto en TI.	Si la contratación es IaaS, remitimos a los objetivos de control de desarrollos propios, con las adecuaciones del caso, dado que operarán bajo infraestructura externa. Si la contratación es SaaS, remitimos a los objetivos referidos a SC, considerando las implicancias de operar dependiendo de una organización de servicios. Con el fin de no reiterar remitimos al apartado 6 en el que trataremos el tema específicamente	Se aplicará el cuestionario definido para SC o desarrollo propio, con más los requerimientos de la modalidad nube, que trataremos en el apartado 6			

Un análisis en particular merece la metodología de desarrollo *Agile*. Adoptan distintas modalidades, pero para sintetizar señalaremos que su característica es que el desarrollo no se realiza en forma secuencial o en cascada, sino en forma flexible con alta participación del usuario y entrega progresiva de aplicaciones incrementales. De modo que permanentemente se van agregado funcionalidades a la aplicación inicial.

No cambian los objetivos de control del auditor con respecto a la integridad y disponibilidad de los datos, pero debe adecuar el enfoque de sus procedimientos a la metodología. Por ejemplo, probablemente deba reparar en una documentación distinta y evaluar su suficiencia. Seguramente no dispondrá de requerimientos detallados de los usuarios, sino tarjetas con "historias de usuarios" que contienen en forma sintética lo necesario para cada iteración. Son procesos que entregan productos funcionando en forma permanente, es decir, si las transacciones del proceso se generan desde la aplicación (la generalidad actualmente) es probable que se vaya incorporando información a medida que se generen nuevas iteraciones y esto impacta en los datos. Deberá preverlo el auditor de EECC al momento de planificar su tarea.

Por último, algunos cambios son de mayor riesgo y requieren la evaluación de expertos, por ejemplo, sistemas operativos.

4.6. Control de accesos

Su objetivo es evitar los accesos no autorizados, tanto físicos como lógicos a los activos de TI.

La protección de accesos físicos es un componente de la seguridad física de TI, que no desarrollaremos en este capítulo, aunque si advertimos que un incidente de seguridad, como por ejemplo una inundación, incendio o atentado, podría privar a la entidad de sus datos con las consecuencias que ya expusimos.

La seguridad lógica radica en la protección de acceso a los sistemas en todas las capas, por ejemplo: sistemas operativos, bases de datos y aplicaciones. Este componente de seguridad de TI es un elemento esencial a tener en cuenta por el auditor de EECC dado que sus debilidades ponen en riesgo la integridad de los datos, en función a que posibilitan incorrecciones ya sea por fraude o error.

Una política de seguridad de accesos se basa en un enfoque integral, considerando las alternativas de acceso interno y remoto, ya sea por personal de la organización que lo hace desde sus instalaciones o a través de trabajo remoto, muy instalado luego del COVID 2019, o por terceros como podrían ser clientes que realizan transacciones con la organización, por ejemplo una adquisición a través de un carrito de compras que dispara un proceso de ventas y cobranzas con impacto en los estados contables. El control de accesos es parte esencial de los sistemas de seguridad de TI con

el fin de proteger los datos a través de distintas capas,³¹ como se muestra en el Gráfico 5 que sigue.

Quién pretenda acceder en forma indebida a los datos, deberá atravesar todas las barreras definidas en la política de seguridad, sin embargo, no es habitual encontrar políticas escritas en empresas pequeñas, pero esto no significa que no existan en mayor o menor medida controles implementados, aunque no siempre con un soporte formal. Dependerá del grado de percepción del riesgo de la Dirección, la envergadura, la complejidad y las necesidades operativas.



Gráfico 5

¿Por qué le interesan al auditor de EECC los controles generales de acceso? La respuesta es porque como todo control general es la plataforma sobre la que operan los controles de aplicación y le dan sustento. Por ejemplo, supongamos que el control de accesos de la aplicación de ventas es eficaz y las transacciones solo pueden ser registradas por usuarios autorizados, pero si un usuario privilegiado o por acceso indebido puede modificar datos directamente sobre la base de datos, el control de aplicación seguiría siendo adecuado pero insuficiente, porque los datos de la transacción podrían alterarse directamente sin que queden pistas. Esto podría darse por ciertas modalidades observables en sistemas precarios o por acción fraudulenta. Como ya hemos resaltado, los controles generales y de aplicación son complementarios.

Dada la complejidad técnica de estos controles de seguridad y ciberseguridad, es probable que se requiera el asesoramiento de un experto.

³¹ Defensa en profundidad. Estrategia militar cuyo fin es hacer que el atacante se desgaste debiendo superar varias barreras.

5. Controles de aplicación.

Los controles de aplicación son específicos de cada aplicación y deberían estar integrados a su desarrollo. Su funcionamiento puede ser manual o automático y tienen como fin, garantizar la exactitud e integridad de los datos que genera un proceso de negocios a través de captura y procesamiento, su disponibilidad y confidencialidad.

Las aplicaciones son programas o conjuntos de programas necesarios para operar un proceso de negocios u otros procesos de la entidad, de modo que pueden ser su soporte operativo para ejecutar transacciones u otros procesos de negocios específicos, interactuando entre sí. Las aplicaciones contables generalmente procesan los datos generados por otras aplicaciones, es decir sus salidas.

En este marco, el auditor de EECC identificará los procesos de negocios y las aplicaciones que los soportan y considerará su relevancia con respecto a la auditoría, para seleccionar aquellas sobre las que aplicará procedimientos para evaluar sus controles y determinar el grado de confiabilidad que le aportan.

A continuación, brindamos una síntesis sobre controles de aplicación que el auditor podrá utilizar como guía básica, adaptándola a las necesidades y características de su encargo particular. Para posibilitar una descripción con un cierto contenido conceptual y de procedimientos, la hemos enfocado a pymes de tamaño y complejidad mediana.

5.1. Conceptos generales

Los controles incluidos en las aplicaciones en su mayoría son de ejecución automática, pero también existen algunos que requieren una intervención humana (manual) para su ejecución, es decir, la aplicación llega hasta la instancia de alerta y requiere una definición o una combinación de ambas.

Ejemplo Gráfico 6: El diseño de la aplicación de ventas contiene un control preventivo parametrizable que determina que hasta un determinado monto de saldo que incluya esa venta se autorizará en forma automática, pero si lo supera, requerirá autorización del gerente de ventas. Este control se incluye en los códigos de la aplicación y opera como se observa en el gráfico. Es un elemento para asegurar la autorización de la venta cuando es requerida por una norma y un elemento más para evitar excesos de saldos que puedan tener efecto en las contingencias por incobrabilidad, en la medida que la parametrización se realice en forma adecuada. Por otra parte, como mínimo podría requerirse que interopere las siguientes aplicaciones: Ventas y cuentas por cobrar (o contabilidad, si cuentas por cobrar no accede a saldos), clientes (por la parametrización)³².

32 Es un ejemplo, dependerá de la arquitectura del sistema.

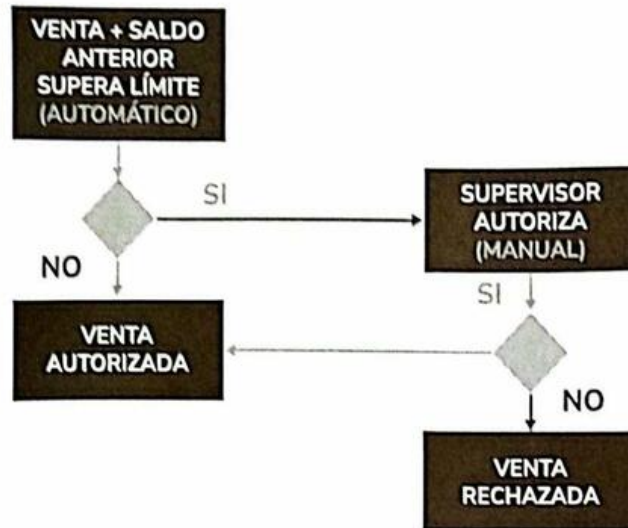


Gráfico 6

El Gráfico 7 ilustra como se incluyen los controles del caso descrito en las líneas de código de la aplicación.³³

```

#Definimos el importe de ventas y el límite de saldo autorizado
importe_ventas= 1000
limite_saldo_autorizado= 900

#Verificamos si el importe supera el límite
if importe_ventas limite > _saldo_autorizado:
    print (f"El importe de ventas ($ {importe_ventas}) supera el limite autorizado($ {limite_saldo_autorizado}).")
    #Se requiere la autorización del supervisor
    autorización_supervisor= input ("¿El supervisor aprueba la transacción? (si/no): ").strip().lower()
    if autorización_supervisor=="si":
        print ("La transacción ha sido aprobada por el supervisor.")
    else:
        print ("La transacción ha sido rechazada por el supervisor.")
else: print (f"El importe de ventas($ {importe_ventas}) está dentro del límite autorizado. La transacción puede continuar.")
  
```

Gráfico 7

Se trata de un control preventivos que opera en forma detectiva.

Los controles preventivos son controles pasivos, advierten o se anticipan a acontecimientos no deseados con el objetivo de evitar su ocurrencia. Desde el punto de vista de las aplicaciones, son todos aquellos que se incluyen desde el diseño y permanecen latentes hasta que un intento dispara la acción, es decir, detecta el hecho y lo impide o detiene la ejecución de un proceso. Su función es también generar una bitácora con los disparos de acciones, registrando el detalle de la transacción que lo provoca y el agente o

³³ Al solo efecto de esquematizar en forma muy sencilla (en Python) la descripción del módulo de un preventivo en la aplicación.

hecho. En síntesis, la inclusión del control en las aplicaciones es preventiva, el fin es detectivo.

Si el diseño de los controles preventivos es adecuado y se incluyen en el desarrollo³⁴ potencian la seguridad de las aplicaciones y es un objetivo de evaluación esencial del auditor de EECC, de acuerdo con la sección II-I.A.i.3.5.2 de la RT 37.

Otros controles son esencialmente detectivos, y estos se ejecutan sobre las bases o archivos con el fin de identificar determinadas situaciones. En estas circunstancias son posteriores a la ocurrencia del hecho. De modo que podríamos afirmar que sería deseable detectar pocos positivos (acción detectiva), dado que pueden interpretarse como ausencia o falencia de los preventivos.

Por último, consideraremos desde el punto de vista de TI que la integridad de datos para que se verifique requiere que se capturan todos los datos en forma exacta y en el momento oportuno, en una transacción autorizada, se actualicen en forma oportuna en un proceso autorizado y en un ambiente de seguridad adecuado.

Las aplicaciones abarcan el ciclo de vida de los datos en un proceso de negocios, es decir, desde su origen hasta su salida al final del proceso ya sea como información definitiva o como insumo para un proceso posterior. En el punto siguiente describiremos una metodología para la evaluación de las aplicaciones y sus controles.

5.2. Metodología para evaluar aplicaciones y sus controles.

A riesgo de ser reiterativos, recordamos que esta metodología y los procedimientos que incluye, es de aplicación para distintos encargos de seguridad de TI (como por ejemplo Sección V.A.,i.14.4 de la RT 37), tal como explicamos en la Introducción, pero nos limitaremos al desarrollo de los esenciales para auditoría de estados y para su funcionamiento adecuado y eficaz. Los controles generales requieren igual condición.

34 Nos hemos referido a "control desde el desarrollo" como política de controles generales de TI

El Gráfico 8 que sigue muestra una relación entre las etapas de un proceso de evaluación de aplicaciones y la RT 37, recordando también que estos procedimientos forman parte y deben integrarse a la documentación de la auditoría.

ETAPA DEL PROCEDIMIENTO	RT 37
Identificación de controles generales de TI y su evaluación (Solo indicativo ya desarrollado).	Sección III. A.i Ítems 3.1 a 3.5 - 3.8 en particular. Su resultado aplica en 3.6, procedimientos de auditoría posterior.
Identificación de los procesos de negocios y actividades relevantes para la auditoría de EC. Identificación de las aplicaciones que las soportan.	Sección III. A.i Ítems 3.2 y 3.3 en particular
Evaluación de riesgo. Posibilidad de generar información incorrecta.	Sección III. A.i Ítems 3.4 en particular
Evaluación de controles (diseño e implementación) en función a los riesgos detectados: Entrada Proceso Salida	Sección III. A.i Ítems 3.5 en particular. Se determina el efecto de las evaluaciones y se definen los procedimientos de auditoría posteriores, generalmente mix de enfoque sustantivo y de cumplimiento. Sección III. A.i. 3.6; 3.7 y 3.8.5.
Evaluación de la eficacia operativa de los controles.	Sección III. A.i. 3.8.1

Gráfico 8

5.3. Identificación de los procesos de negocios y actividades relevantes para la auditoría de EECC. Identificación de las aplicaciones que las soportan

La única forma de entender los datos de un proceso es entender previamente el proceso que los genera, de otra forma no se vislumbra como satisfacer el requisito de integridad. Por ejemplo, en una empresa fabril, la comprensión de la aplicación que soporta un proceso productivo comienza con la visita a la planta, dado que todo el proceso está permanentemente generando datos, aun estando interrumpido. Una aplicación para compras y proveedores requerirá primero comprender el proceso de compras de la entidad y en ambos casos descriptos, la interoperabilidad con otras aplicaciones.

El auditor de EECC deberá identificar los procesos relevantes y su correspondencia con las aplicaciones que lo soportan, particularmente, la capacidad que tienen para capturar, procesar y mantener la integridad de los datos desde su generación hasta la entrega de la información al proceso siguiente.

Una vez identificadas las aplicaciones a evaluar el auditor proseguirá con la evaluación de riesgos.

5.4. Evaluación de riesgos. Posibilidad de generar información incorrecta.

El riesgo de generación de información incorrecta proviene del diseño de las aplicaciones, que no se alinean con los procesos adecuados o porque sus implementaciones fueron inadecuadas.

Ponemos énfasis en que el punto de partida de la evaluación cae sobre la etapa de diseño, dado que condiciona la implementación y la eficacia operativa.

En términos generales los riesgos de información incorrecta parten de:

- deficiencias en el diseño,
- falta de controles en el desarrollo,
- implementación incorrecta,
- cambios no autorizados en los programas o, cambios en los programas sin la intervención de todos sus usuarios,
- acceso indebido a los datos,
- errores en el procesamiento.

El auditor de EECC deberá evaluar estos riesgos en el marco de evaluación de riesgos de su auditoría, considerando la vulnerabilidad, el impacto y la posibilidad de ocurrencia para determinar su materialidad.

5.5. Evaluación de controles (diseño e implementación) en función a los riesgos detectados

De acuerdo con la Sección III.A.i.3.5. de la RT 37 el auditor deberá "obtener un conocimiento del control interno relevante para la auditoría, que será aquel que, a juicio del contador, sea necesario obtener para valorar los riesgos de incorrección significativa en las afirmaciones relativas a tipos de transacciones, saldos contables o información a exponer y para diseñar los procedimientos posteriores de auditoría que respondan a tales riesgos." En este marco, identificará y documentará los controles de entrada, proceso y salida.

En las guías que siguen se describen procedimientos indagatorios sobre objetivos de control referidas a cada etapa.

• Guía para controles de entrada

Tal como explicamos en guías precedentes, debe leerse con las siguientes premisas:

- Los controles de aplicación seleccionados para esta guía (Gráfico 9) son genéricos y se aplican para todo encargo de aseguramiento de TI. Sin embargo, su existencia se orienta a evitar errores, omisiones o inconsistencias en la captura de datos.
- El dato se genera antes que su registro contable. La trazabilidad desde el hecho generador hasta su registro en el sistema contable se valida con estos procedimientos.
- De su adecuación dependen las etapas posteriores, procesamiento y salida

- El ingreso de información al sistema contable puede realizarse en forma manual, por interfaz manual o por interfaz automática. La guía responde a ese esquema.
- Puede agregarse una columna "Descripción" u "Observaciones" a la derecha

Otras formas de captura de información no se han contemplado por cuestiones de extensión, por ejemplo: Acceso web por aplicaciones de trabajo remoto, acceso por WAN desde sucursales, utilización de web service u otros. En estos casos deberán contemplarse los controles generales de seguridad de acceso.

Gráfico 9

GUÍA PARA ELABORAR PROCEDIMIENTOS INDAGATORIOS SOBRE CONTROLES DE ENTRADA						
TIPO DE ENTRADA (1)	Temas claves a considerar por el auditor (2)	Objetivos de control (3)	Preguntas sobre controles esperados (4)	SI (4)	NO (5)	N/A (6)
Manual	Se trata de la carga manual de datos por el usuario a la aplicación, como podría tratarse de ingresos de stock, facturas, asientos contables, consumos de materia prima, entre otros. Los temas a considerar que siguen se refieren a controles habituales tendientes a evitar ingresos incompletos, erróneos o inconsistentes. El auditor determinará en qué medida los evaluará en su encargo específico.					
Autorización	Se trata del control de acceso. Si existe una política general sobre controles de acceso y se trata de un desarrollo propio, la aplicación debería cumplir con los requisitos del caso. Si se trata de software adquirido, la Dirección debería evaluarlo al momento de la adquisición. En las aplicaciones el control de acceso debe requerir al menos, identificación, validación, roles o permisos. También generar un registro de log de transacciones o también llamado log de auditoría, que como mínimo contenga usuario, hora de entrada y salida, terminal y/o dirección IP, programa utilizado y el "antes y después" del registro operado. Un control preventivo para no descuidar es la comunicación fehaciente de responsabilidades al usuario con respecto al uso del acceso y de la información. No hace a la integridad de datos, pero puede impactar en el rubro contingencias laborales.	Política de accesos Identificación de usuario Utilización de algún sistema de validación de usuario (clave, token, biométrica...) Identificación de roles Registro de auditoría Comunicación fehaciente de responsabilidades al usuario.	¿Existe una política para control de accesos? ¿Se requiere identificación de usuario? ¿Se requiere validación de usuario? ¿Se identifica el rol del usuario en la aplicación? ¿Se registra un log de transacciones? ¿Se comunica a los usuarios en forma fehaciente sobre la responsabilidad por el resguardo de su clave y los accesos al sistema?			
Control de edición	Establece el rol de cada usuario dentro de la aplicación, es decir, quién puede crear, modificar o anular información o simplemente acceder en modo consulta, con posibilidad de copia o no. Tiene relación con la operación y facilidad de uso, dado que, por ejemplo, los diseños de pantalla requieren adecuarse al rol. Es esencial para seguridad de la información al establecer niveles de autorización. Por ejemplo, un usuario podría generar una factura, pero no anularla por error durante la confección.	Definiciones de edición Identificación de roles Niveles de actividad en función al rol, consulta o ABM. Formato en pantalla acorde con actividad. Comunicación fehaciente de responsabilidades al usuario.	¿Existe una definición de roles por aplicación? ¿Los roles especifican claramente que acciones permiten? (Puede ser más de una) Por ejemplo: Consulta Alta de datos Modificación de datos. Anulación de datos. Modificación de transacciones en curso. Anulación de transacciones en curso. Modificación en registros cerrados (por ejemplo, asientos contables)			

continua

GUÍA PARA ELABORAR PROCEDIMIENTOS INDAGATORIOS SOBRE CONTROLES DE ENTRADA

TIPO DE ENTRADA (1)	Temas claves a considerar por el auditor (2)	Objetivos de control (3)	Preguntas sobre controles esperados (4)	SI (4)	NO (5)	N/A (6)
Documentos fuente. Balanceo	El ingreso manual implica la existencia de un documento fuente (formulario) desde el cual el operador captura los datos. Este formulario tiene su origen en el relevamiento de los datos de un proceso, de la salida de otra aplicación que no interopera, de un papel de trabajo elaborado en ambiente microinformático ya citado. Su contenido tiene una relación directa con la integridad de la información, de modo que debería tener elementos de control para que el operador constate que el ingreso de datos a la aplicación sea exacto y completo. Las buenas prácticas indican que todos los datos incluidos en el formulario son necesarios y tiene un fin posterior.	Formulario de carga correspondiente con criterios de exactitud e integridad. Formulario predefinido Autorización de formulario de cambio de versión en formularios de carga. Controles de validación contenidos en formularios de carga. Control de lotes. Cantidad de ítems. Control por monto. Cantidad de documentos. Algoritmo de validación.	¿El formulario de carga está definido de acuerdo a las etapas del proceso de negocios? ¿Contempla la captura adecuada de los datos generados en cada etapa? ¿Las modificaciones en el proceso de negocios se impactan en forma inmediata en el formulario de carga? ¿Las modificaciones contemplan una autorización para su vigencia? ¿Su diseño se corresponde con la aplicación de TI que soporta el proceso? ¿Las modificaciones se realizan en forma concordante con la aplicación de TI? ¿Se comunican en forma oportuna los cambios? ¿Contiene controles de validación? Si la respuesta es sí ¿Cuáles? (Descriptivo)			
Validación	El usuario de la aplicación, autorizado para el acceso manual de datos tendrá en pantalla que se denomina "asistente de carga" o similar, que lo guiará en el ingreso de datos al sistema. La correspondencia entre el asistente de carga y el formulario de carga es otro punto clave para asegurar el ingreso exacto y completo de los datos al sistema. En los objetivos de control se detallan algunas validaciones. Para cumplir este objetivo se requerirán validaciones que deberían contemplarse si se trata de desarrollo propio o su adecuación si se trata de SC (parametrizable o no).	Pantalla concordante con formulario de carga. Validación de algoritmo de carga. Exactitud en identificaciones, carga por búsqueda en tabla o redundancia. La falta de tabulación impide o dificulta luego la elaboración de informes por inconsistencias. Integridad de datos por uso de dígito verificador. Campos requeridos, no pueden estar vacíos, o no pueden contener ceros ni espacios. Relaciones lógicas o condicionadas. Controles de signo, secuencia, límite, rango, validez.	¿Los campos a completar en el asistente de carga son requeridos? ¿Se validan las siguientes condiciones de los datos? (De acuerdo con la aplicación) - Tipo de dato: numérico, alfanumérico, alfabético, símbolos. - Control de cantidades, puede establecerse un límite inferior, superior o un rango. - Control de signo. Relación lógica si una condición es verdadera o falsa (Describir).			

continua

GUÍA PARA ELABORAR PROCEDIMIENTOS INDAGATORIOS SOBRE CONTROLES DE ENTRADA					
TIPO DE ENTRADA (1)	Temas claves a considerar por el auditor (2)	Objetivos de control (3)	Preguntas sobre controles esperados (4)	SI (4)	NO (5) N/A (6)
Errores	El error puede impedir el ingreso y generar un rechazo en el campo, por lo que producirá que la carga individual o del lote no pueda realizarse. Con respecto al lote podrá ejecutarse con el rechazo de los registros erróneos. Luego debería verificarse el tratamiento dado a la transacción errónea y su desenlace.	Captura de la integridad del lote Evitar pérdida o error en la captura de las transacciones	¿Existe un registro de rechazos de transacciones? ¿El registro prevé un seguimiento hasta su desenlace? ¿Está definido un responsable para su seguimiento? ¿Cuál es el destino de los rechazos?		
Interfaz manual -	Requerirá la evaluación previa de la aplicación de origen y la revisión de la conversión Si se trata de documentos elaborados en ambiente microinformático, requerirá una evaluación puntual.				
Documentos fuente. Ingreso de registros contables a partir de documentos de trabajo elaborados en ambiente micro informático	Es habitual que en arquitecturas de TI donde las aplicaciones no interoperan resulte necesario elaborar una interfaz manual entre la salida de la aplicación y el ingreso del asiento contable. Dependerá del tamaño, estructura, complejidad y posibilidades de las pymes. Otros asientos contables, pueden provenir de procesos menos directos que el descripto, por ejemplo, las estimaciones contables. Contendrán datos extraídos de las bases transaccionales, o las contables, y a ellos se les aplicarán supuestos y metodología. Otros pueden ser el cálculo de costos, una distribución de costos indirectos, una liquidación de mano de obra, determinaciones impositivas, entre otras. Si para algunas de estas cuestiones por su complejidad se requiere la utilización de un motor de base de datos, es aconsejable que el auditor tenga presente que suelen operar con producto cartesiano y son susceptible de arrojar inconsistencias si los scripts no están perfectamente delimitados (Ejemplo, SQL).	Si se trata de la salida de una aplicación sobre la que luego se ejecuta una interfaz: - Evaluar los controles de aplicación de acuerdo a 4.5, 4.6. - Evaluar la integridad de la transferencia de datos. Si se trata de documentos elaborados en soporte fuera de aplicaciones, por ejemplo, una estimación contable: - La fuente, fiabilidad e integridad de los datos. La preservación como documento de trabajo, dado que fundamenta el asiento contable. Particular énfasis en la disponibilidad e inalterabilidad.	Captura salida de datos de aplicación previa ya revisada. ¿Los datos provenientes de la aplicación previa tienen observaciones? (Si la respuesta es no, prosigue, de lo contrario se evaluará el efecto) ¿Se aplicó una metodología para la conversión? ¿Se revisó la metodología? ¿Se revisó la integridad de los datos posconversión? Registros elaborados en documento previo. ¿Se verificó la integridad de los datos? ¿Se verificó la fiabilidad de los datos? ¿contemplan resguardos de inalterabilidad? ¿Prevé su conservación y acceso por el tiempo de guarda? ¿Está incluido en el sistema de resguardo?		
Interfaz automática. Las aplicaciones interoperan	Se evaluará cada aplicación y se aplicarán pruebas de cumplimiento con respecto al funcionamiento de la interfaz.				

• Controles de procesamiento

Estos controles tienen como objetivo garantizar que los datos mantendrán la integridad y validez durante todo el procesamiento, ejecutándose en forma segura, utilizando los programas correspondientes y por usuarios autorizados, de acuerdo con los requerimientos preestablecidos, tanto funcionales como legales. En esta etapa evaluamos su diseño e implementación.

Actualmente los procesamientos se realizan generalmente en línea y tiempo real, pero los procesos batch siguen vigentes y pueden utilizarse en las pymes. Son procesos que ejecutan acciones mediante determinados programas ya sea capturando datos de las bases o insertándolos mediante lotes (archivos) y se utilizan generalmente para conciliaciones, actualizaciones de datos o cálculos cuando se trata de grandes volúmenes de datos, aunque este requisito no es excluyente. Por ejemplo, si un autoservicio mediano requiere un proceso de valoración de existencia de mercaderías, y su archivo de artículos registra unos 15.000³⁵ ítems, puede realizarlo mediante un proceso batch, si es que la aplicación no lo contempla³⁶. Otro caso, una aplicación de conciliaciones de saldos bancarios, o de inversiones, o de clientes, la cantidad de datos es menor.

Suelen ejecutarse en horarios fuera de pico para posibilitar una mayor disponibilidad de los recursos del sistema, por ejemplo, se ejecutan en horario nocturno porque disminuye la demanda web, y permite asignar mayor celeridad de respuesta a los clientes.

Los procesos batch deben despertar el escepticismo profesional dado que conllevan riesgo de fraude si no están controlados. Es posible realizar alteraciones en los archivos de lote previos al proceso, eliminando, modificando o incluyendo datos fraudulentos, eliminar o agregar transacciones, inclusión de scripts que "bypasean" controles y acceden directo a las bases, simulación de totales, alteración de la trazabilidad, u otros. Por ejemplo, la valoración de stock de nuestro autoservicio del ejemplo podría arrojar resultados en más o en menos de acuerdo con las intenciones, o las conciliaciones armonizar lo que no concilia. El "procesamiento creativo" tiene inspiraciones inagotables.

A continuación, en el Gráfico 10, ofrecemos una guía para evaluar controles de procesamiento bajo las mismas condiciones de interpretación y uso que las anteriores.

35 Esto es habitual, por la variedad de artículos, porque permanentemente cambian las presentaciones y porque la administración de este archivo es administrativamente costosa y a menudo registra desusos e inconsistencias en los artículos de menor movimiento.

36 Es a modo de ejemplo, las potencias de cálculo actuales disponibles en equipos estándar proporcionan una velocidad de procesamiento tal, que esta opción de valoración del inventario, podrían disponerla en tiempo real.

Gráfico 10

GUÍA PARA ELABORAR PROCEDIMIENTOS INDAGATORIOS SOBRE CONTROLES DE PROCESAMIENTO					
Temas claves a considerar por el auditor (1)	Objetivos de control (2)	Preguntas sobre controles esperados (3)	SI (4)	NO (5)	N/A (6)
Los objetivos de control en columna (2), pueden utilizarse tanto en procesos en tiempo real como en batch. Dependerá de la circunstancia y el diseño. Si las aplicaciones procesan en tiempo real, la inmediatez hace que los errores o desvíos sean en tiempo real también. Si el procesamiento es batch, la anomalía o el error es detectable durante el proceso, pero no se elimina el riesgo.	Niveles de autorización para ejecutar el procesamiento Segregación de funciones Si es un proceso continuo, verificar la correspondencia entre totales de salida y entrada. Utilización de los programas que corresponden Gestión de concurrencia Identificación adecuada de archivos Alertas temprana y detección de anomalías y errores. Controles de razonabilidad y/o límite en montos calculados. Existencia de archivos de log, trazabilidad. Control de trazabilidad e integridad de los datos durante el proceso	¿El acceso a las aplicaciones tiene definido un rol específico para su procesamiento? En caso de tratarse de procesos batch ¿existen usuarios autorizados para su ejecución? ¿Existen usuarios autorizados para tratar alertas por anomalías y/o errores durante el proceso? ¿Existe una adecuada segregación de funciones? (Por ejemplo, entre quienes procesan datos y quienes administran bases) En procesos continuos ¿existen controles de totales corrida a corrida? ¿Existen control de concurrencia cuando existe más de un requerimiento sobre un recurso? ¿Existen controles sobre la correspondencia de los archivos a procesar en los procesos batch? (puede agregar descripción) ¿Existen controles sobre los programas que ejecutan los procesos batch? (Puede agregar descripción) ¿Existe un sistema de alertas que advierte sobre datos anómalos? ¿Existe un sistema de tratamiento de errores? ¿Existe un registro de rechazos de transacciones? ¿Se gestionan los rechazos de transacciones? ¿Existen controles de integridad de proceso? (puede agregar descripción, por ejemplo, si se realizan reconciliaciones) ¿Está previsto el recupero si debe volverse atrás en el procesamiento? ¿El proceso genera un registro de log para garantizar la trazabilidad?			

• Controles de salida

Los controles de salida tienen como objetivo verificar que los datos o la información generada por el proceso es íntegra, obedece a las premisas definidas para su procesamiento y se entrega a sus destinatarios, que puede ser un nuevo proceso o un usuario final. En esta etapa evaluamos su diseño e implementación, siempre considerando que hemos seleccionado las aplicaciones que directa o indirectamente tienen un efecto en los estados contables.

Si bien el diseño de los controles de entrada y procesamiento deberían garantizar la integridad de los datos mediante los controles de captura y procesamiento, los controles de la salida por usuarios expertos son el último eslabón para cumplir este requisito, entre otras precauciones a considerar.

De modo que los controles de salida se enfocan a:

- Verificar la integridad de la información, mediante su evaluación por usuarios que entienden los procesos, sus datos y la razonabilidad de sus salidas, amén de utilizar otras técnicas como análisis de tendencias, ratios, comparaciones para evaluar su razonabilidad.
- Acceso debido por medio de distribución segura. Esto es, que la información esté disponible en tiempo y forma para sus usuarios autorizados y para esto se requieren medios de distribución que los garanticen e impidan los accesos indebidos con el fin de proteger su integridad.
- Algunos ejemplos:
 - Listados con información contable: saldos de bancos, deudores, proveedores...
 - Listados de ventas rechazadas
 - Listado de errores en procesos
 - Validación de registros procesados.
- Disponibilidad de acceso en el tiempo. Control de bibliotecas

5.6. Evaluación de la eficacia operativa de los controles.

Una vez identificados los procesos de negocio y sus aplicaciones, los riesgos de incorrecciones en la información, los controles de aplicación en etapa de diseño e implementación, el auditor seguramente constatará su eficacia operativa, con el alcance que defina en sus procedimientos posteriores, a través de pruebas de cumplimiento.

Tal como anticipamos, los procedimientos descriptos en los pasos anteriores son indagatorios y como tales, tienen como objetivo entender los procesos y obtener información sobre riesgos y controles hasta su etapa de implementación inclusive, pero por sí solos, no son generalmente confirmatorios dado que pueden estar influidos por cierta subjetividad y falta de

evidencia del hecho consumado. Por ejemplo, podría consultar acerca del método y controles que se definieron para resguardar la integridad de los datos en la transferencia de un archivo, y esto implicaría consultas a personal idóneo para obtener una descripción convincente e incluso constancias documentales de su implementación, pero esto, en la mayoría de los casos no es suficiente para dar garantías plenas de su eficacia operativa, es decir, que efectivamente funcionen como estaban previstos.

Se requerirán pruebas de cumplimiento de controles, que habitualmente son transaccionales y binarias, se cumplen o no se cumplen. Luego, la medida del cumplimiento, si son manuales determinará su materialidad. Si son controles automáticos, la debilidad o deficiencia se verificará en todos los casos, dado que las aplicaciones no tienen fallos ocasionales cuando la casuística es la misma.

En el cuadro que sigue (Gráfico 11) ejemplificamos algunas pruebas de cumplimiento.

PRUEBAS DE CUMPLIMIENTO DE CONTROLES	
Control a probar (Respuesta afirmativa de la indagatoria)	Procedimiento
Acceso a la aplicación solo por usuarios autorizados.	Obtener lista de autorizados por indagación. Verificar lista con listado de aplicación Obtener listado de log de auditoría de la aplicación Comparar.
La aplicación de facturación procesa todos los pedidos ingresados en el día con fecha del día como cumplimiento de un principio de integridad "en el día se facturan todos los pedidos ingresados y sus artículos".	Obtener el listado de pedidos ingresados en el día (puede ser desde la base de la aplicación o desde el archivo procesado si fue batch). Incluir el listado de artículos que requiere cada pedido. (esto es muy sencillo tomándolo de la base). Obtener el listado de facturas emitidas en el día y su referencia al pedido. Obtener listado de artículos incluidos en facturas. Obtener listado de pedidos rechazados total o parcialmente y artículos vinculados al rechazo, total o parcialmente. Comparar por totales.
Los programas de procesamiento solo admiten datos con determinada definición (signo, valor, tipo....).	Se puede levantar la base y verificar los formatos procesados en su totalidad, en busca de formatos no autorizados. Es válido, pero se limita al universo registrado. Se puede generar un lote de prueba y ejecutarlo. Para eso se requiere contar con un ambiente de prueba en paralelo con las mismas versiones que las instaladas en producción (hay que probarlo). No se deben realizar pruebas en real por el riesgo de alteración de datos reales. Si se detecta un dato fuera de formato, se pueden revisar los logs de auditoría para verificar si el ingreso fue directo.

Gráfico 11

A cada pregunta que hemos ejemplificado en los cuadros que antecede le correspondería, si el auditor resuelve probar los controles, una prueba de cumplimiento de este tipo.

Cómo síntesis, el Gráfico 12 que sigue permite observar que procedimiento de auditoría es aplicable en cada etapa del control y en función al tipo de control.

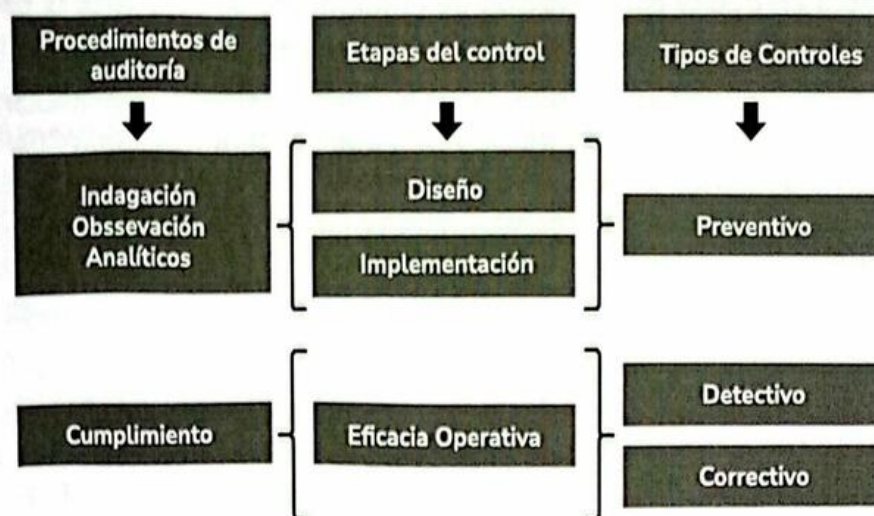


Gráfico 12

6. Utilización de aplicaciones en la nube (cloud computing)

Es una práctica que comenzó a generalizarse con ciertos resquemores promediando la primera década del siglo XXI a nivel de las pymes en Argentina, aunque ya existía desde mucho antes³⁷ en el resto del mundo.

Nuestras normas de auditoría incluyen encargos de aseguramiento específicos desde el año 2012 la RT 35 y desde el año 2013 la RT 37, aunque a la fecha es un nicho de ejercicio profesional no difundido ni explotado en el país. La RT 37 lo contempla en la sección V.C. INFORME SOBRE LOS CONTROLES DE UNA ORGANIZACIÓN DE SERVICIOS, para el caso que este informe respalde controles sobre información financiera.

La situación se da cuando la entidad usuaria contrata con una Organización de Servicios (OS) la tercerización de procesamiento de información de contenido financiero, que luego utilizará para la preparación de los EECC. Esta contratación puede ser bajo modalidades IaaS o SaaS, ya explicadas en el Gráfico 4. También la modalidad SaaS podría ser total (aplicación de contabilidad general y aplicaciones complementarias) o parcial, solo algunas aplicaciones complementarias, pero que generen datos relevantes para el sistema contable.

El auditor de EECC tiene en estos casos una limitación al alcance dado que su cliente es la empresa usuaria, por lo tanto, no tiene acceso para evaluar el control interno de la OS. Las normas de auditoría contemplan como salvar esta situación mediante el encargo ya citado, y si el auditor de EECC deposita confianza en este informe, supera la limitación basándose en este informe.

³⁷ En 1992 el AICPA emite las SAS 70, referida a informes SOC (Service Organization Control), Informes sobre controles de una organización de servicios.

La contratación de servicios de nube implica un riesgo crítico para el auditado, dado que transfiere a la OS la custodia de sus datos es decir de su activo más valioso, además de otros riesgos de uso. Para el auditor, el riesgo está en que la conservación de la fuente de su evidencia la tiene un tercero fuera del dominio del auditado y del propio.

Esta relación entre la entidad usuaria y la OS se formaliza mediante un contrato de acuerdo (o nivel) de servicios que se identifica como SLA³⁸, generalmente de adhesión cuando se trata de pequeños usuarios.

Por cuestiones de extensión, recomendamos la lectura de la sección VC de la RT 37³⁹ y el Capítulo 6 del Informe N° 25 emitido por FACPCE.⁴⁰

7. Misceláneas

El avance tecnológico impacta en los procesos de negocio y los sistemas de información de las entidades, sean o no pymes. Parafraseando a COBIT⁴¹, la tecnología ha eliminado el tiempo y la distancia y cambia radicalmente las organizaciones y las prácticas de negocios, incrementando la dependencia de la información, brindando oportunidades y riesgos. Estos conceptos que ya tienen 25 años, han seguido un proceso inverso a la obsolescencia.

A continuación, resumiremos algunas "nuevas" tecnologías:

• Robótica de software

Si bien su difusión se potencia a partir del año 2000 con herramientas RPA⁴², sus orígenes se remontan a la década de 1980 y consiste en la automatización de procesos con software que se ejecuta sobre bases de datos o documentos e interactúa en la capa de usuario.

Un ejemplo podría ser el proceso de una venta (simplificado). Un cliente realiza un pedido y el "robot" accede en forma automática a las aplicaciones requeridas (clientes, stock, finanzas... o un CRM) utilizando las interfaces gráficas como si fuera un humano. Consultará stock, verificará estado del crédito, precios, bonificaciones, eventualmente enviará un mail de consulta o información de rechazo al cliente y finalmente si corresponde emitirá la factura, generará el despacho y enviará un aviso por mail.

¿En que impacta este proceso automático en la auditoría de EC? En esencia, requiere la misma (o mayor) fiabilidad de datos (stock, pre-

38 Service Level Agreement por sus siglas en ingles.

39 O en su caso para mayor extensión la Norma Internacional de Encargo de Aseguramiento 3402 del IAASB, que es su fuente.

40 Puede acceder por este link: https://www.facpce.org.ar/wp-content/uploads/2022/03/N-FORME_No_25.pdf

41 IT Governance Institute, (2000), Directrices de Auditoría del Marco referencial COBIT: Un Objetivo de Control en TI es una definición del resultado o propósito que se desea alcanzar implementando procedimientos de control específicos dentro de una actividad de TI.

42 RPA (Robotic Process Automation) Automatización Robótica de Procesos

cios, saldos, límite de venta, cliente...) que si el proceso fuera manual. La seguridad podría provenir de la automatización, que dependerá de la definición e implementación de los programas que integran el robot de software.

En síntesis, la confiabilidad del proceso y los datos que impactarán en el EECC, dependerá de la fiabilidad de los datos y del proceso. No cambian los procedimientos que hemos descrito en este capítulo, solo hay que adecuar como aplicarlos.⁴³

La automatización es tan segura como los resultados de los procedimientos aplicados por el auditor.

- **Blockchain y Smart Contracts.**

Tal como la robótica, las cadenas de bloques y los contratos inteligentes (que no lo son, son programas) tiene su origen hace más de 40 años, blockchain por ejemplo en 1979. Se exteriorizó por las criptomonedas, pero su difusión, fuera de este hecho, no ha tenido la evolución esperada. No obstante, alguna empresa podrá utilizar este sistema para operaciones y resguardo de la información en forma inalterable. El análisis es muy amplio y excede este capítulo, pero podemos concluir que, si la entidad auditada utiliza esta metodología, los registros son absolutamente inalterables. Es el único atributo del registro, no prueba existencia, ocurrencia, valor, legitimidad u otros requisitos. Por último, la inalterabilidad solo se da en la cadena, si se extrae el dato para otro uso, pierde la condición.

Con respecto a los Smart Contracts, su uso está comenzando a difundirse y la cuestión para el auditor, es que si requiere evaluarlo, tendrá que leer líneas de código dado que no hay una "impresión en texto" del contrato. Seguramente requerirá la asistencia de un experto⁴⁴.

8. Controles de TI del contador

Mas allá de los comentarios que pueda merecernos⁴⁵, la realidad es que resulta habitual tratándose de empresas pequeñas con estructura administrativa muy reducida, que el procesamiento de su información la realice el mismo profesional que luego emite el informe de auditoría.

Si bien dependerá de la modalidad y alcance del servicio y que el contador tendría un conocimiento de las fortalezas y debilidades de su estructura de TI, los riesgos a los que la información está expuesta son los mismos, por lo tanto, no encontramos diferencias en cuanto a los controles requeridos.

⁴³ Remitimos al Capítulo 3 del Informe N° 25 emitido por la FACPCE. También incluye el uso de robótica por el auditor.

⁴⁴ Remitimos al Capítulo 9 del Informe N° 25 emitido por la FACPCE

⁴⁵ El Código de ética unificado lo permite.

Sí, existe un agravante. El contador es depositario de la información de su cliente, cuestión que no es novedosa, porque con "soportes papel" también lo era. Simplemente, los riesgos son distintos.

9. Conclusiones

La necesidad de evaluar los procesos de generación de información es inherente a la auditoría de estados contables, simplemente, a partir de la década de 1990 y con la difusión de las computadoras personales, la evolución de internet y las comunicaciones, al aumento de la potencia de cálculo y el almacenaje correspondiendo con bajas en los costos que facilitan la accesibilidad, ha generado un avance exponencial de la incidencia (y dependencia) de la tecnología en los sistemas de información, y esto impactó fuertemente en el ejercicio profesional en todos sus aspectos.

En lo que nos ocupa, este capítulo sintetiza aspectos básicos de controles de TI y algunos procedimientos para evaluación de riesgos y controles, no agota el tema, sino que pretende despertar expectativas y cubrir el objetivo de conformar una guía para que el profesional pueda orientar la elaboración de sus procedimientos indagatorios, en tanto se trate de una organización de tamaño y complejidad media. La extensión imposibilita agregar procedimientos de cumplimiento para cada caso.

Para otros encargos de aseguramiento, por ejemplo, los incluidos en la sección V.A.i.14.4 de la RT 37 *Sistemas de control interno referentes a tecnologías de información de una entidad*⁴⁶, también son aplicables los descriptos, pero deben complementarse con un enfoque más amplio, no solo orientados a información contable.

Por último, los sistemas de información (diseño e implementación) y los encargos de aseguramiento sobre tecnología, ofrecen para la profesión un campo profesional con oportunidades inagotables de servicios. Desde luego, la conformación de equipos interdisciplinarios, complementando con expertos informáticos y legales es ya un hecho y una necesidad que potencia las posibilidades, alcance y calidad de los servicios.

46 La Constitución de la Provincia de Bs As delega en la legislatura la reglamentación del ejercicio profesional. En este marco la Ley 10.620 de ejercicio profesional, en el inciso a apartado 6 del artículo 12 otorga las siguientes competencias a los Contadores Públicos: **"Definición, análisis, diseño e implementación de sistemas de información económico-financiera en los entes públicos y privados; auditoría de sistemas de datos y de información para la determinación de su grado de eficiencia y seguridad; evaluación y determinación de la configuración del equipamiento a utilizar para el procesamiento de los datos; emisión de opinión técnica y tramitación destinada a la autorización de dichos medios por parte del órgano de contralor;"**

10. Bibliografía

- IT Governance Institute, (2000), Directrices de Auditoría del Marco referencial COBIT:
- FACPCE. Informe N° 25: Aplicación de nuevas tecnologías en al trabajo de auditoría. URL https://www.facpce.org.ar/NORMASWEB/index_argentina.php?c=18&sc=203
- FACPCE. Resolución Técnica N° 37: Normas de Auditoría, Revisión, Otros Encargos de Aseguramiento, Certificación y Servicios Relacionados. url: https://www.facpce.org.ar/NORMASWEB/index_argentina.php?c=18&sc=204
- IAASB. NIA 315 (Revisada 2019), Identificación y valoración del riesgo de incorrección material. URL: <https://www.iaasb.org/publications/nia-315-revisada-2019-identificacion-y-valoracion-del-riesgo-de-incorreccion-material-y>